

Cedar Ridge Capital Advisors, LLC

Information Security and Privacy Policy

Document owner	Chief Compliance Officer
Approved by	Managing Members
Effective date	December 1, 2025
Version	1.8
Classification	Internal Policy - Fictional Test Document

This fictional document is part of the RegSpan realistic testing corpus. It is written as an ordinary company policy, not as a model answer or legal opinion.

Document Control

Version	Effective date	Summary of change	Approval
1.8	December 1, 2025	Current approved issue	Managing Members

Policy Overview

Cedar Ridge is a 28-person adviser that relies on a cloud CRM, portfolio accounting software, a hosted email service, and two custodians.

The sections below describe the firm's approved practices. Department procedures may provide additional implementation detail.

1. Purpose, Scope, and Applicability

Cedar Ridge is a 28-person adviser that relies on a cloud CRM, portfolio accounting software, a hosted email service, and two custodians.

This document establishes the firm's internal approach to protecting customer information and responding to information-security events. It applies to employees, temporary personnel, contractors, offices, information systems, paper records, and relevant service-provider relationships.

Business units may maintain more detailed procedures, but those procedures may not reduce the protections stated here. Legal and Compliance interpret regulatory obligations and resolve conflicts with other retention, privacy, cybersecurity, or contractual requirements.

2. Definitions

Term	Working definition
Customer information	A record containing nonpublic personal information about a customer of a financial institution, including information handled by or on behalf of the firm and information provided by another financial institution about its customers.
Sensitive customer information	Customer information whose compromise could create a reasonably likely risk of substantial harm or inconvenience to an identified individual.
Customer information system	Information resources and related infrastructure used to collect, process, maintain, use, share, disseminate, or dispose of customer information.
Service provider	A person or entity that receives, maintains, processes, or is permitted access to customer information through services provided directly to the firm.
Incident	Unauthorized access to or use of customer information, or an event reasonably likely to involve such access or use.

3. Roles and Responsibilities

Role	Core responsibilities
Executive sponsor	Provides authority, resources, and escalation support.
Incident Response Lead	Directs triage, response activities, documentation, and closure.
Information Security / Technology	Investigates, contains, restores, and validates systems.
Compliance and Legal	Interprets notice, recordkeeping, regulatory, and law-enforcement obligations.
Business and data owners	Identify affected processes, systems, information, and customers.
Service-provider owner	Coordinates vendor evidence, notices, remediation, and follow-up.
Communications / Customer Service	Prepares approved customer communications and handles inquiries.

4. Incident Response Program

Cedar Ridge Capital Advisors, LLC maintains this written incident response program as part of its customer information safeguards framework. The program is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information. It applies to customer information in paper, electronic, and other forms, including information maintained by service providers on the firm's behalf.

The program begins when monitoring, employee reporting, a service-provider notice, or another reliable source indicates that unauthorized access or use has occurred or is reasonably likely to have occurred. The Incident Response Lead opens a case, assigns severity, preserves relevant records, and coordinates assessment, containment, customer-notice analysis, recovery, and closure.

- Detect: monitor security alerts, access anomalies, customer complaints, lost devices, vendor notices, and misuse reports.
- Respond: investigate, contain, control, communicate, and document decisions.
- Recover: restore approved services, remediate root causes, validate controls and access, and complete a post-incident review.

5. Incident Triage and Containment

For every suspected incident involving unauthorized access to or use of customer information, the response team assesses the nature and scope of the incident. The assessment identifies the date and method of access, affected accounts and users, duration, privileges obtained, systems involved, and whether data was viewed, copied, altered, transmitted, or destroyed.

The assessment must identify each customer information system that may have been affected and the types of customer information stored or processed in those systems. The team records whether sensitive customer information may be involved and identifies affected individuals when reasonably possible.

- isolate compromised hosts, accounts, applications, or network segments;
- disable or reset credentials and rotate keys or tokens;
- block malicious infrastructure and preserve monitoring;
- search for additional affected systems and unauthorized persistence;
- coordinate controlled shutdowns when needed to prevent further unauthorized access or use.

6. Customer Breach Notification Procedure

Legal evaluates customer notification after unauthorized access to sensitive customer information. The goal is to send notice as soon as practical, with 30 days used as an internal target.

Legal may extend the target when the investigation remains active or material facts are still developing.

7. Required Customer Notice Content

Customer notices describe the incident, identify the categories of information involved, provide an estimated incident date when available, and direct customers to the firm's toll-free response line and incident email address.

The notice template also advises customers to monitor accounts and contact the firm if suspicious activity appears.

8. Third-Party Security and Breach Escalation

The firm obtains security questionnaires and assurance reports from selected vendors and requires vendors to cooperate with investigations. Vendors must report incidents promptly.

Business owners escalate provider notices to Compliance and Technology for review and follow-up.

9. Safeguards Program

The safeguards program applies to customer information in the firm's possession and customer information handled or maintained on its behalf. It also applies to nonpublic personal information received from another financial institution about that institution's customers. Controls are selected to ensure confidentiality, protect against anticipated threats or hazards, and prevent unauthorized access or use that could result in substantial harm or inconvenience.

- Administrative safeguards: risk assessment, assigned ownership, workforce training, access approval, change management, service-provider oversight, and periodic control review.
- Technical safeguards: multi-factor authentication, least privilege, encryption in transit and at rest where appropriate, endpoint protection, vulnerability management, secure configuration, logging, monitoring, and tested backups.
- Physical safeguards: controlled office and records-room access, visitor management, locked storage, secure transport, clean-desk expectations, and destruction controls for paper and media.

10. Secure Disposal and Media Handling

The firm properly disposes of consumer information and customer information by taking reasonable measures to prevent unauthorized access to or use of the information during and after disposal. Disposal occurs only after applicable retention, legal hold, contractual, and business requirements are satisfied.

- Paper records are placed in locked consoles and destroyed by cross-cut shredding or a vetted destruction provider.
- Electronic files are securely deleted using approved methods; encryption keys may be destroyed when cryptographic erasure is appropriate.
- Devices and removable media are inventoried, sanitized, or physically destroyed before reuse or disposal.
- Cloud repositories, backups, and service-provider systems are included in disposition instructions and verified when material customer information is involved.
- Certificates or confirmations of destruction are retained when a third party performs disposal.

11. Books and Records

Compliance maintains the current policy, annual reviews, and records of significant incidents. Records are kept under the corporate retention schedule.

The records coordinator applies the corporate retention schedule and responds to examination requests.

12. Incident Documentation

The incident manager maintains a contemporaneous incident file containing alerts, system and identity logs, relevant exports, screenshots, investigation notes, affected-system and data inventories, decisions, approvals, containment steps, customer-notice analysis, provider communications, recovery tests, and closure documentation.

Relevant logs and volatile information are preserved promptly. Exports are stored in access-controlled case folders with source, collection time, custodian, and integrity information when material to the investigation. Routine log retention is not shortened while an incident, investigation, examination, or legal hold is open.

13. Legal, Regulatory, and Law-Enforcement Coordination

Only senior management may contact regulators or law-enforcement authorities. Employees should refer external inquiries to Legal.

Legal manages any follow-up with the requesting authority and informs management of next steps.

14. Service Restoration and Closure

The incident team coordinates recovery with business owners and vendors and documents outstanding remediation.

The response coordinator closes the incident after outstanding actions have been assigned.

15. Training, Testing, and Review

Personnel receive training appropriate to their roles. Employees are trained to report suspicious access, lost devices, misdirected information, customer complaints suggesting account compromise, and unusual service-provider communications.

The policy owner reviews the document annually and may conduct a tabletop exercise when resources permit.

16. Annual Privacy Notice Administration

Compliance reviews annually whether the firm must deliver privacy notices and coordinates any required mailing or electronic delivery.

Approval

Policy owner	Chief Compliance Officer	Date	December 1, 2025
Approving body	Managing Members	Version	1.8